

Integrität und Verfügbarkeit: Ein umfassendes Prüfkonzzept für die moderne Datenhaltung

Autor: Mevluet Polat

Themenbereich: IT-Governance, Datensicherheit und Compliance

Einleitung

In einer Ära, in der Daten als das «neue Gold» der globalen Wirtschaft bezeichnet werden, ist deren Schutz und die Sicherstellung ihrer ständigen Verfügbarkeit nicht mehr nur eine rein technische Aufgabe der Informatikabteilung. Vielmehr hat sich die Datensicherung (Backup) und Archivierung zu einer zentralen Säule der Corporate Governance und der rechtlichen Compliance entwickelt. Insbesondere im Schweizer Kontext, geprägt durch das revidierte Datenschutzgesetz (DSG) und branchenspezifische Regulierungen (wie die FINMA-Rundschreiben für den Finanzsektor), ist die nachweisbare Einhaltung von Datenhaltungsvorgaben von existenzieller Bedeutung für Unternehmen.

Der vorliegende Artikel befasst sich mit dem systematischen Prüfkonzzept zur Einhaltung dieser Vorgaben. Basierend auf den Leitsätzen von Mevluet Polat werden die verschiedenen Prüfarten, die strategische Planung von Restore-Tests, die Notwendigkeit einer lückenlosen Protokollierung sowie das Management von Abweichungen analysiert. Ziel ist es, ein tiefgreifendes Verständnis dafür zu schaffen, warum eine blossе Sicherung ohne systematisches Prüfkonzzept ein unkalkulierbares Risiko darstellt.

1. Das Prüfkonzzept und die verschiedenen Prüfarten

Ein effektives Management der Datenhaltung beginnt nicht bei der Technologie, sondern bei der Planung. Mevluet Polat definiert das **Prüfkonzzept** als einen systematischen Plan, der festlegt, wie, wann und durch wen die Einhaltung der Datenhaltungsvorgaben geprüft wird. Ohne ein solches Konzzept bleiben Kontrollen oft zufällig und lückenhaft.

1.1 Internes Audit

Das interne Audit ist das primäre Kontrollorgan innerhalb der Organisation. Hierbei führt entweder die IT-Abteilung selbst (Selbstprüfung) oder eine unabhängige interne Revision eine regelmässige Überprüfung der Backup- und Archivierungsprozesse durch.

Beispiel: Eine mittelgrosse Schweizer Kantonalbank führt quartalsweise ein internes Audit

durch. Dabei wird geprüft, ob die im Reglement festgelegten Aufbewahrungsfristen für E-Mails (oft 10 Jahre gemäss Geschäftsbücherverordnung GeBüV) technisch korrekt im Archivsystem umgesetzt sind.

1.2 Externes Audit

Während interne Prüfungen effizient sind, bringt das externe Audit eine notwendige Objektivität und Glaubwürdigkeit ein. Externe Prüfer (wie z.B. spezialisierte IT-Revisionsgesellschaften) bewerten die Prozesse mit einem Blick von aussen und gleichen sie mit Industriestandards wie ISO 27001 ab. Dies ist besonders für die Berichterstattung gegenüber Stakeholdern und Aufsichtsbehörden essenziell.

1.3 Technische Kontrolle

In der modernen IT sind manuelle Prüfungen aufgrund der Datenmenge kaum mehr möglich. **Technische Kontrollen** übernehmen diese Aufgabe automatisiert. Monitoring-Systeme überwachen kontinuierlich den Status der Backup-Jobs.

Beispiel: Ein Dashboard in einem Rechenzentrum in Zürich zeigt in Echtzeit an, wenn eine inkrementelle Sicherung eines SQL-Servers fehlgeschlagen ist. Das System generiert sofort ein Ticket im Incident-Management-System, noch bevor ein menschlicher Operator den Fehler bemerkt hätte.

1.4 Der Restore-Test als Königsdisziplin

Polat betont zu Recht, dass die praktische Wiederherstellung (Restore-Test) die wichtigste Prüfmassnahme ist. Ein Backup, das sich nicht wiederherstellen lässt, ist faktisch nicht existent. In der Wissenschaft spricht man oft vom «Schrödinger-Backup»: Man weiss erst, ob es funktioniert, wenn man es öffnet (wiederherstellt).

2. Planung und Durchführung von Restore-Tests

Die theoretische Sicherheit einer erfolgreich abgeschlossenen Sicherung trägt oft. Datenbankkorruption, Inkompatibilitäten bei der Hardware oder fehlerhafte Verschlüsselungs-Keys können eine Wiederherstellung unmöglich machen. Daher ist eine strukturierte Testplanung unerlässlich.

2.1 Terminierung und Ressourcen

Restore-Tests dürfen kein Nebenprodukt des Tagesgeschäfts sein. Sie müssen im Jahresplan fest terminiert werden. Dies stellt sicher, dass sowohl die technische Infrastruktur als auch die notwendigen Fachverantwortlichen zur Verfügung stehen.

2.2 Testumfang und Szenarien

Es ist unrealistisch, täglich das gesamte Unternehmen wiederherzustellen. Daher legt der Testplan fest, welche Systeme (z.B. ERP, CRM, File-Server) in welchem Rhythmus (monatlich, quartalsweise, jährlich) getestet werden. Dabei müssen verschiedene Szenarien berücksichtigt werden:

- Wiederherstellung einzelner Dateien (User-Error).
- Wiederherstellung einer kompletten Datenbank (Systemfehler).
- Full-Site-Recovery (Desaster-Szenario, z.B. Brand im Rechenzentrum).

2.3 Die isolierte Testumgebung

Ein entscheidender Punkt in Polats Konzept ist die **isolierte Testumgebung**. Ein Wiederherstellungstest darf niemals die produktiven Systeme gefährden.

Beispiel: Ein Pharmaunternehmen möchte die Wiederherstellung seines SAP-Systems testen. Würde dies im normalen Netzwerk geschehen, könnten IP-Adresskonflikte oder automatisierte E-Mail-Benachrichtigungen an Kunden ausgelöst werden. Die Wiederherstellung erfolgt daher in einem «Sandboxed»-Netzwerk (VLAN), das keine Verbindung zur Aussenwelt hat.

2.4 Erfolgskriterien und Dokumentation

Ein Test ohne klare Erfolgskriterien ist wertlos. Vorab muss definiert werden:

1. **Recovery Time Objective (RTO):** Wie lange darf die Wiederherstellung maximal dauern?
2. **Recovery Point Objective (RPO):** Welcher Datenstand muss erreicht werden (Maximaler Datenverlust)?
3. **Datenintegrität:** Sind die Daten konsistent und die Applikationen startfähig?

Alle Ergebnisse fließen in einen standardisierten **Testbericht**, der die Grundlage für das Management-Reporting bildet.

3. Protokollierung und Reporting: Die Basis der Transparenz

Transparenz ist das Fundament jeder Compliance. Ohne detaillierte Aufzeichnungen über die Aktivitäten im Bereich der Datenhaltung können Verantwortlichkeiten nicht wahrgenommen werden.

3.1 Das Backup-Protokoll

Jeder einzelne Sicherungsvorgang muss ein Protokoll erzeugen. Dieses enthält Informationen wie:

- Start- und Endzeitpunkt.
- Übertragenes Datenvolumen.

- Erfolgsstatus (Success, Warning, Failed).
- Identifikation der gesicherten Objekte.

3.2 Protokollauswertung und Trendanalyse

Die tägliche Analyse der Protokolle ist eine operative Pflichtaufgabe. Doch Polat geht einen Schritt weiter: Die **Trendanalyse**. Langfristige Auswertungen ermöglichen es, Probleme zu erkennen, bevor sie kritisch werden.

Beispiel: Die Trendanalyse zeigt, dass das Datenvolumen des Fileservers in den letzten drei Monaten überproportional gewachsen ist (z.B. um 30% statt der üblichen 5%). Dies könnte auf eine Fehlkonfiguration, einen Bot oder schlicht auf eine Kapazitätsgrenze hindeuten, die bald erreicht wird. Proaktive Massnahmen können nun eingeleitet werden, bevor das Backup-Medium voll ist und Sicherungen fehlschlagen.

3.3 Management-Reporting und Eskalation

Die Unternehmensleitung (Geschäftsleitung/Verwaltungsrat) trägt die Letztverantwortung für die Risiken des Unternehmens. Daher benötigt sie regelmässige, kompakte Berichte. Ein «Management-Reporting» sollte nicht aus hunderten Seiten technischer Logs bestehen, sondern den Status der Datensicherung in Kennzahlen (KPIs) zusammenfassen.

Bei kritischen Fehlern – etwa wenn die Kernbankensoftware drei Tage hintereinander nicht gesichert werden konnte – muss ein automatischer **Eskalationsmechanismus** greifen, der die nächsthöhere Führungsebene informiert.

4. Massnahmen bei Abweichungen: Der kontinuierliche Verbesserungsprozess

Ein Prüfsystem, das Fehler findet, aber keine Konsequenzen nach sich zieht, ist wirkungslos. Das Management von Abweichungen folgt dem Prinzip des kontinuierlichen Verbesserungsprozesses (KVP).

4.1 Abweichungsanalyse

Wird ein Fehler festgestellt, muss die Ursache (Root Cause) ermittelt werden. War es ein Hardwaredefekt? Ein Softwarebug? Oder ein menschlicher Fehler bei der Konfiguration? Eine systematische Analyse verhindert, dass nur die Symptome bekämpft werden.

4.2 Sofortmassnahmen und Massnahmenplan

Bei kritischen Risiken (z.B. Totalausfall der Sicherung einer produktiven Datenbank) sind **Sofortmassnahmen** erforderlich. Dies könnte eine manuelle Sicherung auf ein anderes Medium

sein oder die Bereitstellung von Notfall-Hardware.

Parallel dazu wird ein langfristiger **Massnahmenplan** erstellt. Dieser definiert:

- Was genau getan wird.
- Wer dafür verantwortlich ist (Responsibility).
- Bis wann die Umsetzung erfolgt (Deadline).

Beispiel: Wenn bei einem Restore-Test festgestellt wurde, dass die Wiederherstellungszeit (RTO) von 24 Stunden deutlich überschritten wurde, könnte der Massnahmenplan die Anschaffung schnellerer Storage-Systeme oder die Optimierung der Netzwerkbandbreite vorsehen.

4.3 Wirksamkeitskontrolle und Konzeptanpassung

Nachdem eine Massnahme umgesetzt wurde, muss geprüft werden, ob sie das Problem tatsächlich gelöst hat (**Wirksamkeitskontrolle**). Sollten Abweichungen wiederholt auftreten, deutet dies auf ein strukturelles Problem hin. In diesem Fall muss das gesamte Datenhaltungskonzept oder der zugrunde liegende Prozess angepasst werden. Dies zeigt die Dynamik des Modells: Es ist kein statisches Regelwerk, sondern ein lernendes System.

5. Wissenschaftliche Einordnung und Relevanz für die Praxis

Die Ausführungen von Mevluet Polat lassen sich nahtlos in moderne IT-Management-Frameworks wie **COBIT** (Control Objectives for Information and Related Technologies) oder **ITIL** (Information Technology Infrastructure Library) integrieren.

5.1 Bezug zum Schweizer Datenschutzgesetz (DSG)

Das revidierte Schweizer Datenschutzgesetz verlangt «angemessene technische und organisatorische Massnahmen» (TOM) zum Schutz der Persönlichkeit und der Grundrechte der Personen, über die Daten bearbeitet werden. Ein systematisches Prüfkonzept, wie von Polat beschrieben, ist ein direkter Beweis für die Einhaltung dieser gesetzlichen Sorgfaltspflichten. Im Falle einer Datenschutzverletzung (Data Breach) kann die Dokumentation der Restore-Tests und Audits als Entlastungsbeweis dienen, dass das Unternehmen alles Zumutbare unternommen hat, um die Verfügbarkeit der Daten sicherzustellen.

5.2 Wirtschaftliche Aspekte

Wissenschaftliche Studien zeigen, dass die Kosten für die Behebung eines Datenverlusts ohne funktionierende Backups um ein Vielfaches höher sind als die Investitionen in ein Prüfkonzept. Berücksichtigt man die Ausfallkosten (Downtime), den Reputationsschaden und mögliche

Bussen durch Regulierungsbehörden, wird die proaktive Prüfung zur betriebswirtschaftlichen Notwendigkeit.

5.3 Praktisches Beispiel: Ransomware-Abwehr

In Zeiten von Ransomware-Angriffen (Erpressungssoftware) gewinnen die von Polat geforderten Massnahmen eine neue Dimension. Angreifer versuchen heute oft gezielt, zuerst die Backups zu löschen oder zu verschlüsseln, bevor sie das Hauptsystem angreifen.

- **Technische Kontrolle:** Monitoring-Systeme könnten Alarm schlagen, wenn plötzlich massenhaft Daten im Backup geändert werden (Entropie-Analyse).
- **Restore-Test:** Regelmässige Tests stellen sicher, dass die Backups «immun» gegen die Verschlüsselung der Quellsysteme sind (z.B. durch unveränderbare Speicher, sog. Immutable Backups).

6. Zusammenfassung und Fazit

Die Sicherstellung der Datenhaltungsvorgaben ist eine komplexe Aufgabe, die weit über das blosses Drücken eines «Backup»-Knopfes hinausgeht. Wie Mevluet Polat eindrücklich darlegt, erfordert eine resiliente IT-Infrastruktur ein ineinandergreifendes System aus Planung, Kontrolle, Analyse und Verbesserung.

Die Kernerkenntnisse lassen sich wie folgt zusammenfassen:

1. Ein **systematisches Prüfkonzzept** ist das Fundament für Compliance und operative Sicherheit.
2. **Restore-Tests** sind das einzige Mittel, um die tatsächliche Funktionsfähigkeit der Datensicherung nachzuweisen. Sie müssen in isolierten Umgebungen und nach klaren Kriterien durchgeführt werden.
3. **Protokollierung und Trendanalyse** ermöglichen den Übergang von einer reaktiven zu einer proaktiven IT-Organisation.
4. **Management-Reporting** schliesst die Lücke zwischen Technik und Unternehmensführung und stellt sicher, dass Risiken auf der richtigen Ebene wahrgenommen werden.
5. Ein strukturierter Umgang mit **Abweichungen** garantiert, dass aus Fehlern gelernt wird und die Resilienz des Unternehmens stetig wächst.

Abschliessend lässt sich festhalten, dass Datenhaltung im 21. Jahrhundert eine Vertrauensfrage ist. Kunden, Partner und Behörden vertrauen darauf, dass Daten sicher sind. Ein Prüfkonzzept nach den hier vorgestellten Grundsätzen ist das Instrument, um dieses Vertrauen durch Fakten zu untermauern. Unternehmen, die diese Prinzipien vernachlässigen, riskieren nicht nur technische Probleme, sondern ihre gesamte Existenzgrundlage in einer digitalisierten Welt.

Quellenverzeichnis

- **Polat, Mevluet.** Folien 22–25: *Prüfung und Einhaltung der Vorgaben / Prüfkonzert, Restore-Tests, Protokollierung, Massnahmen bei Abweichungen.*
- **Schweizerische Eidgenossenschaft.** *Bundesgesetz über den Datenschutz (DSG) vom 25. September 2020 (Stand am 1. September 2023).* SR 235.1.
- **Schweizerische Eidgenossenschaft.** *Verordnung über die Führung und Aufbewahrung der Geschäftsbücher (Geschäftsbücherverordnung, GeBüV) vom 24. April 2002 (Stand am 1. Januar 2013).* SR 221.431.
- **ISACA.** *COBIT 2019 Framework: Governance and Management Objectives.* Schaumburg, IL, USA.
- **International Organization for Standardization.** *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements.*
- **ITIL 4 Foundation.** *IT Service Management.* AXELOS, TSO (The Stationery Office).
- **FINMA.** *Rundschreiben 2023/1: Operative Risiken und Resilienz – Banken.* Eidgenössische Finanzmarktaufsicht.
- **Tannenbaum, A. S., & Van Steen, M.** *Distributed Systems: Principles and Paradigms.* (Zur Theorie der Datenkonsistenz und Wiederherstellung).